

Incident Playbook — Business Email Compromise / Account Takeover

Response to compromised M365 accounts and payment-fraud attempts

Document ID: BVT-IRP-047

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Immediate Containment (First 30 Minutes)

- 1 Disable sign-in for the affected account OR reset password + revoke all sessions/refresh tokens (Entra: 'Revoke sessions'); with MFA fatigue suspected, also require re-registration of MFA.
- 2 Check and remove: inbox rules (forwarding/delete rules are the #1 artifact), mailbox delegates, mail-forwarding SMTP settings, and rogue OAuth app consents.
- 3 Search sign-in logs: source IPs, locations, times of unauthorized access — export before they age out.
- 4 Block observed attacker IPs/user agents via conditional access where feasible.
- 5 Check whether the account sent phishing internally/externally; purge those messages tenant-wide and warn recipients.

Financial Fraud Branch (If Payment Involved)

- 1 If fraudulent payment was made or is pending: contact the bank's fraud department IMMEDIATELY to attempt recall — minutes matter.
- 2 File FBI IC3 report and request a Financial Fraud Kill Chain for wires $\geq$ \$50,000 within 72 hours.
- 3 Preserve the fraudulent emails with full headers; do not tip off the attacker by replying.
- 4 Verify no vendor/customer banking records were altered in accounting systems.

Scope and Impact

- Determine dwell time from first anomalous sign-in; review mailbox audit for items accessed/searched (eDiscovery where licensed) — this drives breach-notification analysis.
- Check for lateral movement: other accounts with same-password reuse, MFA registrations added, SharePoint/OneDrive mass downloads.
- Determine attack vector: phishing page, MFA fatigue, token theft (AiTM) — AiTM requires session revocation, password reset alone is insufficient.

Hardening After BEC

- Enforce phishing-resistant MFA for finance and executives; conditional access blocking legacy auth and unfamiliar geographies.
- External-forwarding block; anomaly alerting for new inbox rules; verify DMARC at quarantine/reject.
- Payment-verification policy: mandatory out-of-band callback for any banking change (train finance staff; document in client policy).
- If mailbox contained personal information that was accessed, run breach analysis with counsel (BVT-IRP-052).